https://www.skills.google/focuses/46454931?parent=lti_session

Identificar vulnerabilidades e técnicas de correção

experiment

Laboratório

schedule

1 hora 30 minutos

universal_currency_alt

Sem custo financeiro

show_chart

Introdutório

info

Este laboratório pode incorporar ferramentas de IA para ajudar no seu aprendizado.

ícone de "importante" IMPORTANTE:

ícone de notebook/computador Conclua este laboratório prático usando um computador ou notebook.

ícone de verificação Só 5 tentativas são permitidas por laboratório.

ícone de alvo do teste É comum não acertar todas as questões na primeira tentativa e precisar refazer uma tarefa. Isso faz parte do processo de aprendizado.

ícone de cronômetro Depois que o laboratório é iniciado, não é possível pausar o tempo. Depois de 1h30, o laboratório será finalizado, e você vai precisar recomeçar.

ícone de dica Para saber mais, confira as Dicas técnicas do laboratório.

Informações gerais da atividade

Identificar vulnerabilidades e implementar técnicas de correção são atividades essenciais para a segurança e a estabilidade de vários sistemas e aplicativos. Muitos aplicativos e sistemas lidam com informações sensíveis, como informações de identificação pessoal, registros financeiros ou propriedade intelectual. A identificação de vulnerabilidades ajuda a impedir o acesso não autorizado a esses dados e possíveis violações. Geralmente é mais barato eliminar as vulnerabilidades no início do desenvolvimento do que lidar com as violações de segurança depois. O custo para corrigir vulnerabilidades costuma ser muito maior que o custo da prevenção.

Analistas de segurança como você verificam regularmente a ocorrência de vulnerabilidades para identificar e eliminar os pontos fracos antes de ataques maliciosos, mitigando proativamente as ameaças em potencial. Assim você consegue identificar a superfície de ataque do aplicativo, entender possíveis vias de exploração e priorizar as áreas mais importantes para melhoria.

Neste laboratório, além de aprender a configurar e executar um aplicativo vulnerável, você também vai procurar vulnerabilidades nele.

Cenário

O Cymbal Bank desenvolveu um novo aplicativo bancário para clientes corporativos, que será hospedado e implantado na nova infraestrutura em nuvem. Javier, o Chief Information Security Officer (CISO), quer priorizar a segurança do aplicativo antes do lançamento para os clientes. Chloe, a líder da sua equipe, encarregou você de identificar e mitigar eventuais vulnerabilidades no aplicativo. Com o Web Security Scanner do Google Cloud, você vai verificar se o aplicativo contém alguma vulnerabilidade do tipo "scripting em vários sites" (XSS), uma das principais vulnerabilidades de aplicativos da Web segundo a OWASP®.

Confira como fazer a tarefa: primeiro, você vai criar um endereço IP estático e iniciar uma máquina virtual. Segundo, implantar o aplicativo vulnerável. Terceiro, configurar e executar o aplicativo. Quarto, acessar e verificar o aplicativo. Quinto, corrigir as vulnerabilidades e verificar o aplicativo de novo.

Configuração

Antes de clicar em "Começar o laboratório"

Leia as instruções a seguir. Os laboratórios são cronometrados e não podem ser pausados. O timer é iniciado quando você clica em Começar o laboratório e mostra por quanto tempo os recursos do Google Cloud vão ficar disponíveis.

Neste laboratório prático, você pode fazer as atividades por conta própria em um ambiente cloud de verdade, não em uma simulação ou demonstração. Você vai receber novas credenciais temporárias para fazer login e acessar o Google Cloud durante o laboratório.

Confira os requisitos para concluir o laboratório:

Acesso a um navegador de Internet padrão (recomendamos o Chrome).

Observação: para executar este laboratório, use o modo de navegação anônima ou uma janela anônima do navegador. Isso evita conflitos entre sua conta pessoal e a conta de estudante, o que poderia causar cobranças extras na sua conta pessoal.

Tempo para concluir o laboratório---não se esqueça: depois de começar, não será possível pausar o laboratório.

Observação: não use seu projeto ou conta do Google Cloud neste laboratório para evitar cobranças extras na sua conta.

Como iniciar seu laboratório e fazer login no console do Google Cloud

Clique no botão Começar o laboratório. No painel Detalhes do laboratório à esquerda, você verá o seguinte:

Tempo restante

O botão Abrir console do Google Cloud

As credenciais temporárias que você vai usar neste laboratório

Outras informações, se forem necessárias

Observação: se for preciso pagar pelo laboratório, um pop-up vai aparecer para você escolher a forma de pagamento.

Se você estiver usando o navegador Chrome, clique em Abrir console do Google Cloud (ou clique com o botão direito do mouse e selecione Abrir link em uma janela anônima). A página de login será aberta em uma nova guia do navegador.

Dica: é possível organizar as guias em janelas separadas, lado a lado, para alternar facilmente entre elas.

Observação: se a caixa de diálogo Escolha uma conta aparecer, clique em Usar outra conta.

Se necessário, copie o Nome de usuário do Google Cloud abaixo e cole na caixa de diálogo de login. Clique em Próximo.

"Nome de usuário do Google Cloud"

Copiado.

Você também encontra o Nome de usuário do Google Cloud no painel Detalhes do laboratório.

Copie a Senha do Google Cloud abaixo e cole na caixa de diálogo seguinte. Clique em Próximo.

"Senha do Google Cloud"

Copiado.

Você também encontra a Senha do Google Cloud no painel Detalhes do laboratório.

Importante: você precisa usar as credenciais fornecidas no laboratório, e não as da sua conta do Google Cloud.

Observação: usar sua própria conta do Google Cloud neste laboratório pode gerar cobranças extras.

Nas próximas páginas:

Aceite os Termos e Condições

Não adicione opções de recuperação nem autenticação de dois fatores nesta conta temporária

Não se inscreva em testes gratuitos

Depois de alguns instantes, o console será aberto nesta guia.

Observação: para acessar a lista dos produtos e serviços do Google Cloud, clique no Menu de navegação no canto superior esquerdo. Menu do console do Google Cloud com o ícone do menu de navegação em destaque

Tarefa 1: iniciar uma máquina virtual

Nesta tarefa, você vai criar um endereço IP estático e iniciar a máquina virtual que vai executar o aplicativo vulnerável.

Na barra de título do console do Google Cloud, clique no ícone Ativar o Cloud Shell (Ícone "Ativar o Cloud Shell"). Se for solicitado, clique em Continuar.

Copie o comando a seguir no terminal do Cloud Shell:

```
gcloud compute addresses create xss-test-ip-address --region="REGION"
```

Copiado.

O comando vai criar um endereço IP estático chamado xss-test-ip-address na região REGION. O IP será usado para verificar o aplicativo da Web vulnerável.

Pressione ENTER.

Se for solicitado, clique em Autorizar.

Copie o comando a seguir no terminal do Cloud Shell:

```
gcloud compute addresses describe xss-test-ip-address \
--region="REGION" --format="value(address)"
```

Copiado.

O comando vai mostrar o endereço IP estático que você gerou.

Pressione ENTER.

Copie o endereço IP indicado pelo comando e salve no bloco de notas. Você vai usar o endereço em uma próxima tarefa.

Copie o comando a seguir no terminal do Cloud Shell:

gcloud compute instances create xss-test-vm-instance --address=xss-test-ip-address --no-service-account \

--no-scopes --machine-type=e2-micro --zone="ZONE" \

--metadata=startup-script='apt-get update; apt-get install -y python3-flask'

Copiado.

O comando vai criar uma instância de VM para executar o aplicativo vulnerável.

Pressione ENTER.

Observação: o script de inicialização vai instalar o python-flask, um framework de aplicativo da Web que será usado para executar um aplicativo Python simples. O aplicativo demonstra a vulnerabilidade scripting em vários sites (XSS), um tipo comum em aplicativos da Web.

Clique em Verificar meu progresso para confirmar que você concluiu a tarefa corretamente.

Iniciar uma máquina virtual

Tarefa 2: configurar e executar o aplicativo vulnerável

Nesta tarefa, você vai baixar e extrair os arquivos do aplicativo da Web vulnerável e implantá-lo por SSH no navegador.

Primeiro, você vai criar uma regra de firewall para permitir que o Web Security Scanner acesse o aplicativo vulnerável.

Copie o comando a seguir no terminal do Cloud Shell:

gcloud compute firewall-rules create enable-wss-scan \

--direction=INGRESS --priority=1000 \

--network=default --action=ALLOW \

--rules=tcp:8080 --source-ranges=0.0.0.0/0

Copiado.

O comando vai criar uma regra de firewall que permite que qualquer endereço IP acesse o aplicativo da Web. Assim o Web Security Scanner vai poder acessar o aplicativo para fazer a verificação.

Pressione ENTER.

Em seguida, use uma conexão SSH para acessar a instância de VM.

No console do Google Cloud, clique no menu de navegação (Menu de navegação).

Selecione Compute Engine > Instâncias de VM.

Na coluna Conectar da página Instâncias de VM, clique no botão SSH ao lado da instância de teste.

Uma nova janela do navegador será aberta com a conexão SSH para a instância de VM.

Talvez apareça uma mensagem pop-up pedindo autorização para acessar as VMs por SSH no navegador. Clique em Autorizar.

Agora, extraia os arquivos do aplicativo da Web.

Copie o comando abaixo na página do SSH no navegador (não no Cloud Shell):

gsutil cp gs://cloud-training/GCPSEC-ScannerAppEngine/flask_code.tar . && tar xvf flask_code.tar

Copiado.

O comando vai baixar e extrair os arquivos do aplicativo da Web vulnerável.

Pressione Enter.

Por último, copie o comando abaixo na página do SSH no navegador:

python3 app.py

Copiado.

O comando vai iniciar o aplicativo.

Pressione ENTER.

Vai aparecer uma mensagem indicando que o aplicativo está em execução.

Observação: como o aplicativo da Web foi instalado para uso em desenvolvimento, talvez o arquivo de configuração contenha vulnerabilidades. É importante testar todo aplicativo antes do uso em uma rede aberta ao público.

Observação: não feche a página do SSH no navegador ao fazer a próxima tarefa, já que o aplicativo precisa continuar em execução.

Clique em Verificar meu progresso para confirmar que você concluiu a tarefa corretamente.

Configurar e executar o aplicativo vulnerável

Tarefa 3: acessar o aplicativo vulnerável

Nesta tarefa, você vai verificar se o aplicativo contém a vulnerabilidade chamada de scripting em vários sites (XSS). As vulnerabilidades XSS podem ser exploradas por scripts maliciosos, como código HTML, no conteúdo que será depois veiculado aos navegadores da Web.

Com o aplicativo ainda em execução, abra uma nova janela do navegador.

Copie o URL abaixo na guia do navegador. Substitua <YOUR_EXTERNAL_IP> pelo endereço IP estático da VM, que você copiou no bloco de notas na Tarefa 1:

<script>http://<YOUR_EXTERNAL_IP>:8080</script>

Copiado.

Com isso, vai aparecer o portal do banco corporativo Cymbal Bank com um formulário da Web.

Copie o código HTML abaixo, incluindo as tags de script, no formulário da Web:

<script>alert('This is an XSS Injection to demonstrate one of OWASP vulnerabilities')</script>

Copiado.

O código vai injetar uma vulnerabilidade OWASP®.

Uma página da Web do aplicativo de demonstração do Cymbal Bank exibe um formulário que contém um script XSS

Clique em POST.

O código injetado exibiu uma mensagem de volta ao navegador. Essa ação por si só não é maliciosa, mas invasores podem introduzir código malicioso em um aplicativo vulnerável para roubar dados ou para implantar malware nos dispositivos dos usuários.

Será aberta uma janela de alerta com esta mensagem: "This is an XSS Injection to demonstrate one of OWASP vulnerabilities".

Which security vulnerability is associated with actions performed in this task?

Ransomware

SQL Injection

Cross-Site Request Forgery (CSRF)

Cross-Site Scripting (XSS)

Tarefa 4: verificar o aplicativo

Nesta tarefa, você vai procurar vulnerabilidades no aplicativo com o Web Security Scanner.

Primeiro, ative a API Web Security Scanner.

No console do Google Cloud, clique no menu de navegação (Menu de navegação).

Selecione APIs e serviços > APIs e serviços ativados. A página APIs e serviços será exibida.

Clique em + Ativar APIs e serviços.

No campo de pesquisa, digite Web Security Scanner e pressione ENTER.

Selecione API Web Security Scanner.

Selecione Ativar.

Agora, procure vulnerabilidades no aplicativo.

No console do Google Cloud, clique no menu de navegação (Menu de navegação).

Selecione Segurança > Web Security Scanner. Talvez seja preciso expandir o menu suspenso Mais produtos no menu de navegação.

Se a API Web Security Scanner estiver ativada, a página Web Security Scanner do Cloud vai exibir os detalhes das Configurações de verificação.

Na barra de ferramentas do Cloud Web Security Scanner, clique em + Nova verificação.

Na seção Nome, digite Cross-Site Scripting scan.

Na seção URLs iniciais, o campo URLs iniciais 1 já foi preenchido com o endereço IP estático.

Adicione o símbolo de dois pontos (:) e o número da porta, 8080, ao final do endereço IP. O URL inicial 1 vai ficar assim:

<script>http://<EXTERNAL_IP>:8080</script>

Copiado.

Se estiver presente, exclua URL inicial 2.

Na seção URLs excluídos, a opção Autenticação precisa ser Nenhuma, e a opção Programar precisa ser Nunca. Não mude os outros campos.

Clique em Salvar para criar a verificação.

Clique em Executar verificação para começar.

Volte à janela do SSH no navegador.

Na janela do SSH no navegador, vão aparecer registros gerados pelo Web Security Scanner, que está procurando vulnerabilidades em todos os URLs possíveis.

Quando a verificação terminar, volte ao console do Google Cloud.

Observação: a verificação pode levar 5 a 10 minutos.

A guia Resultados vai mostrar as vulnerabilidades XSS, demonstrando que o Web Security Scanner consegue detectar problemas desse tipo.

As vulnerabilidades também aparecem na guia Vulnerabilidades do Security Command Center.

Clique em Verificar meu progresso para confirmar que você concluiu a tarefa corretamente.

Verificar o aplicativo

Tarefa 5: corrigir as vulnerabilidades

Nesta tarefa, você vai corrigir a vulnerabilidade XSS do aplicativo e executá-lo de novo com a correção.

Para corrigir as vulnerabilidades atuais, a recomendação é fazer a validação e o escape dos dados não confiáveis enviados pelos usuários, o que também é uma regra da OWASP®.

Para fazer isso, você vai incluir, no código do aplicativo vulnerável, linhas que fazem a validação e o escape dos dados enviados pelos usuários.

Volte à página do SSH no navegador conectado à instância de VM.

Pressione CTRL + C para interromper a execução do aplicativo. Ou clique no ícone Enviar combinação de teclas, no canto direito de cima do SSH no navegador, para enviar a combinação CTRL + C.

Agora, edite o arquivo app.py no editor nano.

Copie o comando abaixo na página do SSH no navegador:

nano app.py

Copiado.

O comando vai abrir o editor de código nano.

Pressione ENTER.

Para corrigir a vulnerabilidade XSS, faça a validação da variável de string de saída. Essa string é a saída processada dos dados que o usuário inseriu no formulário da Web.

O aplicativo não pode aceitar a entrada do usuário como código HTML, mas sim fazer o escape dos caracteres especiais escritos pelo usuário. Para isso, localize as duas linhas que definem a string de saída:

```
# output_string = "".join([html_escape_table.get(c, c) for c in input_string])

output_string = input_string
```

Copiado.

Remova o símbolo # da primeira linha e adicione ao início da linha seguinte, com atenção para que o recuo do código fique correto. As linhas finais vão ficar assim:

```
@app.route('/output')

def output():

  output_string = "".join([html_escape_table.get(c, c) for c in input_string])

  # output_string = input_string

  return flask.render_template("output.html", output=output_string)
```

Copiado.

Pressione CTRL + X para fechar o nano, Y para salvar as mudanças e ENTER para confirmar.

Copie o comando a seguir no terminal do Cloud Shell:

python3 app.py

Copiado.

O comando vai executar o aplicativo de novo.

Pressione ENTER.

Clique em Verificar meu progresso para confirmar que você concluiu a tarefa corretamente.

Corrigir as vulnerabilidades

Tarefa 6: verificar o aplicativo da Web de novo

Nesta tarefa, você vai verificar se ainda há vulnerabilidades no aplicativo.

Volte à página Cloud Web Security Scanner no console do Google Cloud.

Clique em Executar para executar a verificação de novo.

Observação: a verificação pode levar 5 a 10 minutos.

A guia Resultados vai indicar que não há mais vulnerabilidades.

Clique em Verificar meu progresso para confirmar que você concluiu a tarefa corretamente. Espere até o final da verificação para receber o crédito pela tarefa.

Verificar o aplicativo da Web de novo

Conclusão

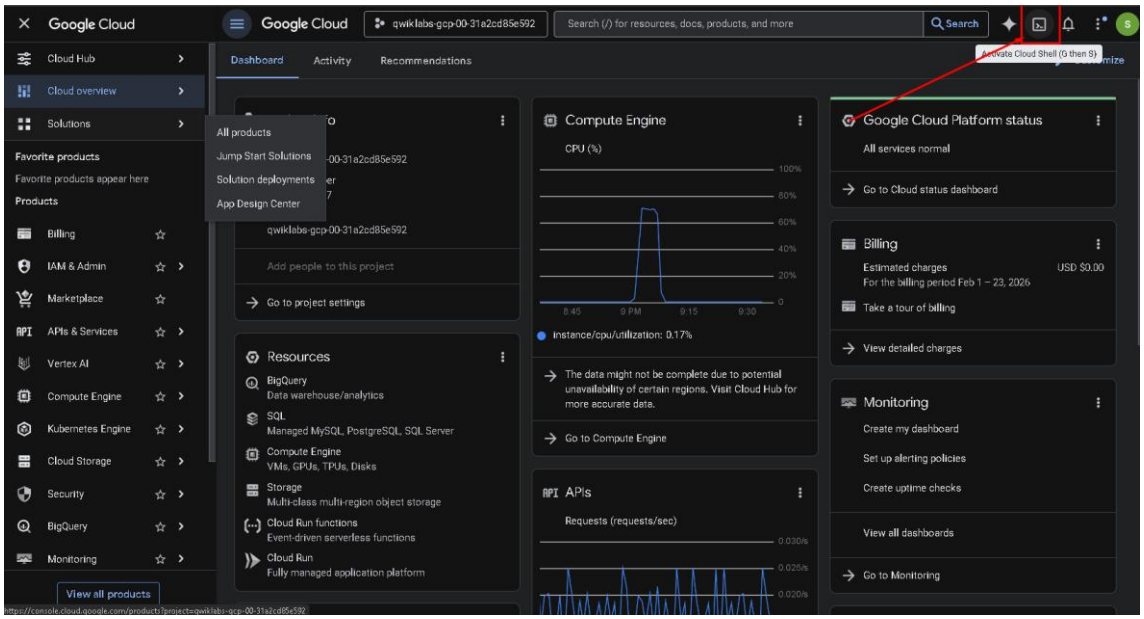
Bom trabalho!

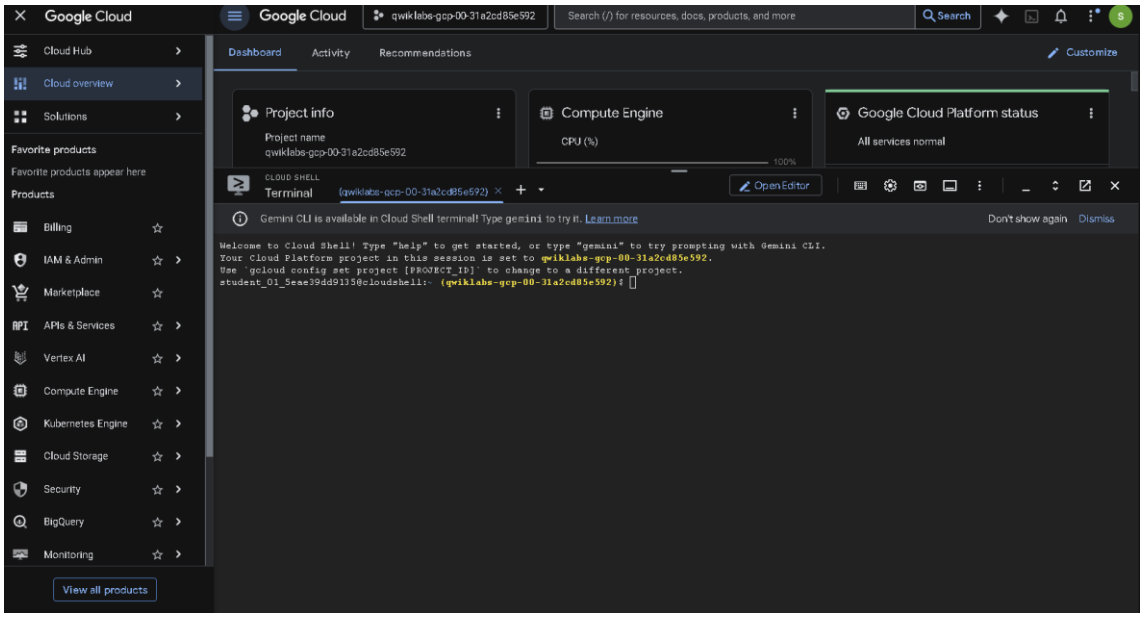
Neste laboratório, você adquiriu experiência prática na verificação de vulnerabilidades em aplicativos. Você aprendeu que é importante que analistas de segurança procurem vulnerabilidades em aplicativos, algo essencial para identificar e corrigir possíveis pontos fracos, gerenciar riscos, cumprir as normas e manter uma postura de segurança robusta para proteger os ativos e a reputação da organização.

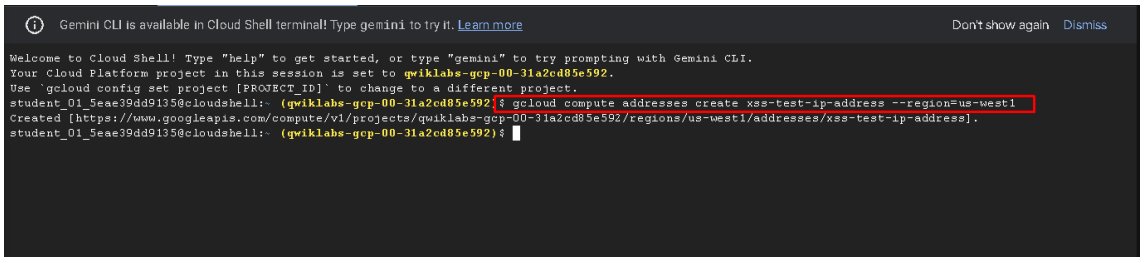
Ao fechar as lacunas de segurança e eliminar os pontos fracos, você evita explorações, minimiza o impacto dos incidentes de segurança e cumpre a regulamentação do setor.

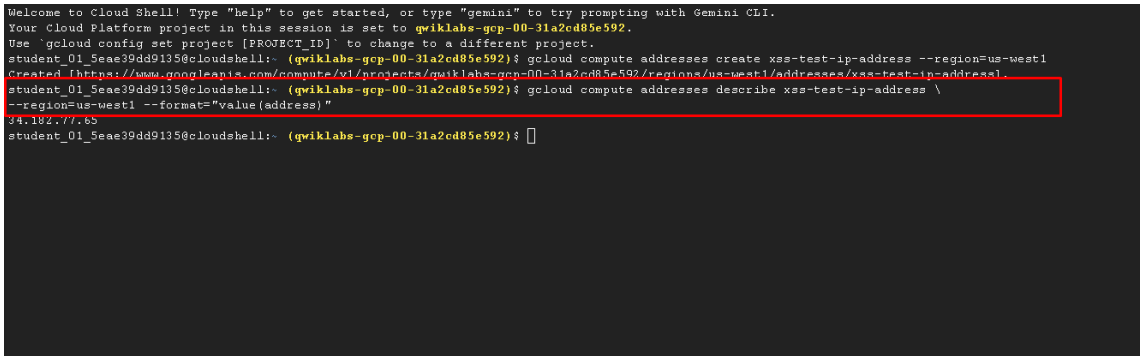
Neste laboratório, você concluiu um dos aspectos fundamentais das estratégias proativas de segurança cibernética.

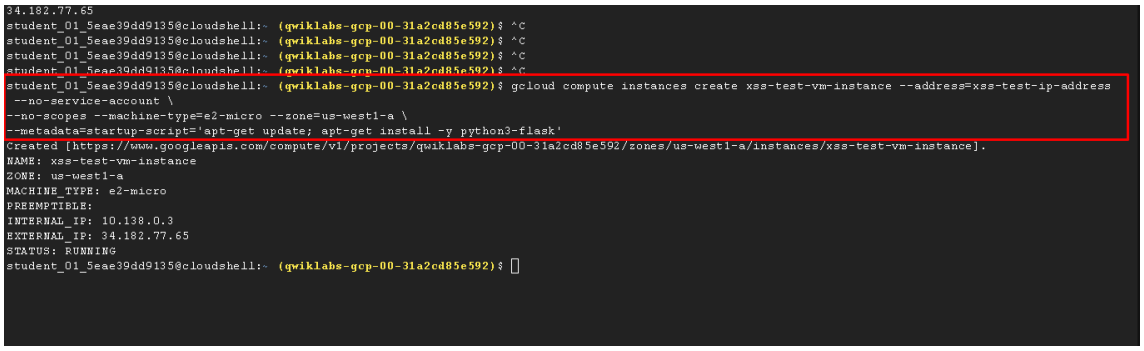
Tarefa 1: iniciar uma máquina virtual




Google Cloud
Cloud Hub
Cloud overview
Solutions
Favorite products
Favorite products appear here
Products
Billing
IAM & Admin
Marketplace
APIs & Services
Vertex AI
Compute Engine
Kubernetes Engine
Cloud Storage
Security
BigQuery
Monitoring
View all products
Dashboard
Activity
Recommendations
Customize
Project info
Project name
qwiklabs-gcp-00-31a2cd85e592
Compute Engine
CPU (%)
Google Cloud Platform status
All services normal
CLOUD SHELL
Terminal
Open Editor
Gemini CLI is available in Cloud Shell terminal! Type gemini to try it. Learn more
Don't show again
Dismiss
Welcome to Cloud Shell! Type "help" to get started, or type "gemini" to try prompting with Gemini CLI.
Your Cloud Platform project in this session is set to qwiklabs-gcp-00-31a2cd85e592.
Use `gcloud config set project [PROJECT_ID]` to change to a different project.
student_01_5eae39dd9135@cloudshell:~ (qwiklabs-gcp-00-31a2cd85e592)$


Gemini CLI is available in Cloud Shell terminal! Type gemini to try it. Learn more
Don't show again
Dismiss
Welcome to Cloud Shell! Type "help" to get started, or type "gemini" to try prompting with Gemini CLI.
Your Cloud Platform project in this session is set to qwiklabs-gcp-00-31a2cd85e592.
Use `gcloud config set project [PROJECT_ID]` to change to a different project.
student_01_5eae39dd9135@cloudshell:~ (qwiklabs-gcp-00-31a2cd85e592)$ gcloud compute addresses create xss-test-ip-address --region=us-west1
Created [https://www.googleapis.com/compute/v1/projects/qwiklabs-gcp-00-31a2cd85e592/regions/us-west1/addresses/xss-test-ip-address].
student_01_5eae39dd9135@cloudshell:~ (qwiklabs-gcp-00-31a2cd85e592)$


Welcome to Cloud Shell! Type "help" to get started, or type "gemini" to try prompting with Gemini CLI.
Your Cloud Platform project in this session is set to qwiklabs-gcp-00-31a2cd85e592.
Use `gcloud config set project [PROJECT_ID]` to change to a different project.
student_01_5eae39dd9135@cloudshell:~ (qwiklabs-gcp-00-31a2cd85e592)$ gcloud compute addresses create xss-test-ip-address --region=us-west1
Created [https://www.googleapis.com/compute/v1/projects/qwiklabs-gcp-00-31a2cd85e592/regions/us-west1/addresses/xss-test-ip-address].
student_01_5eae39dd9135@cloudshell:~ (qwiklabs-gcp-00-31a2cd85e592)$ gcloud compute addresses describe xss-test-ip-address \
--region=us-west1 --format="value(address)"
34.182.77.65
student_01_5eae39dd9135@cloudshell:~ (qwiklabs-gcp-00-31a2cd85e592)$


34.182.77.65
student_01_5eae39dd9135@cloudshell:~ (qwiklabs-gcp-00-31a2cd85e592)$ ^C
student_01_5eae39dd9135@cloudshell:~ (qwiklabs-gcp-00-31a2cd85e592)$ ^C
student_01_5eae39dd9135@cloudshell:~ (qwiklabs-gcp-00-31a2cd85e592)$ ^C
student_01_5eae39dd9135@cloudshell:~ (qwiklabs-gcp-00-31a2cd85e592)$ ^C
student_01_5eae39dd9135@cloudshell:~ (qwiklabs-gcp-00-31a2cd85e592)$ gcloud compute instances create xss-test-vm-instance --address=xss-test-ip-address
--no-service-account \
--no-scopes --machine-type=e2-micro --zone=us-west1-a \
--metadata=startup-script='apt-get update; apt-get install -y python3-flask'
Created [https://www.googleapis.com/compute/v1/projects/qwiklabs-gcp-00-31a2cd85e592/zones/us-west1-a/instances/xss-test-vm-instance].
NAME: xss-test-vm-instance
ZONE: us-west1-a
MACHINE_TYPE: e2-micro
PREEMPTIBLE:
INTERNAL_IP: 10.138.0.3
EXTERNAL_IP: 34.182.77.65
STATUS: RUNNING
student_01_5eae39dd9135@cloudshell:~ (qwiklabs-gcp-00-31a2cd85e592)$

Clique em **Verificar meu progresso** para confirmar que você concluiu a tarefa corretamente.

Iniciar uma máquina virtual

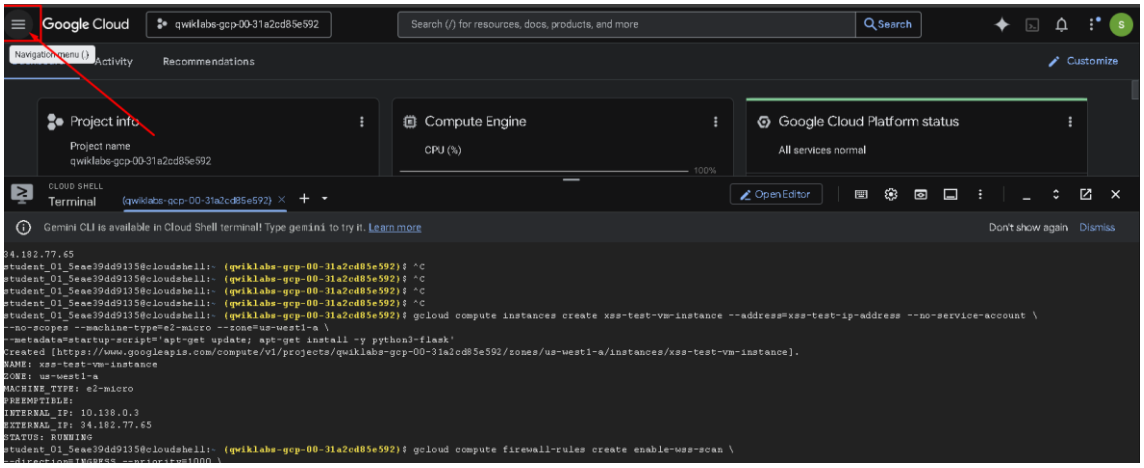
Verificar meu progresso

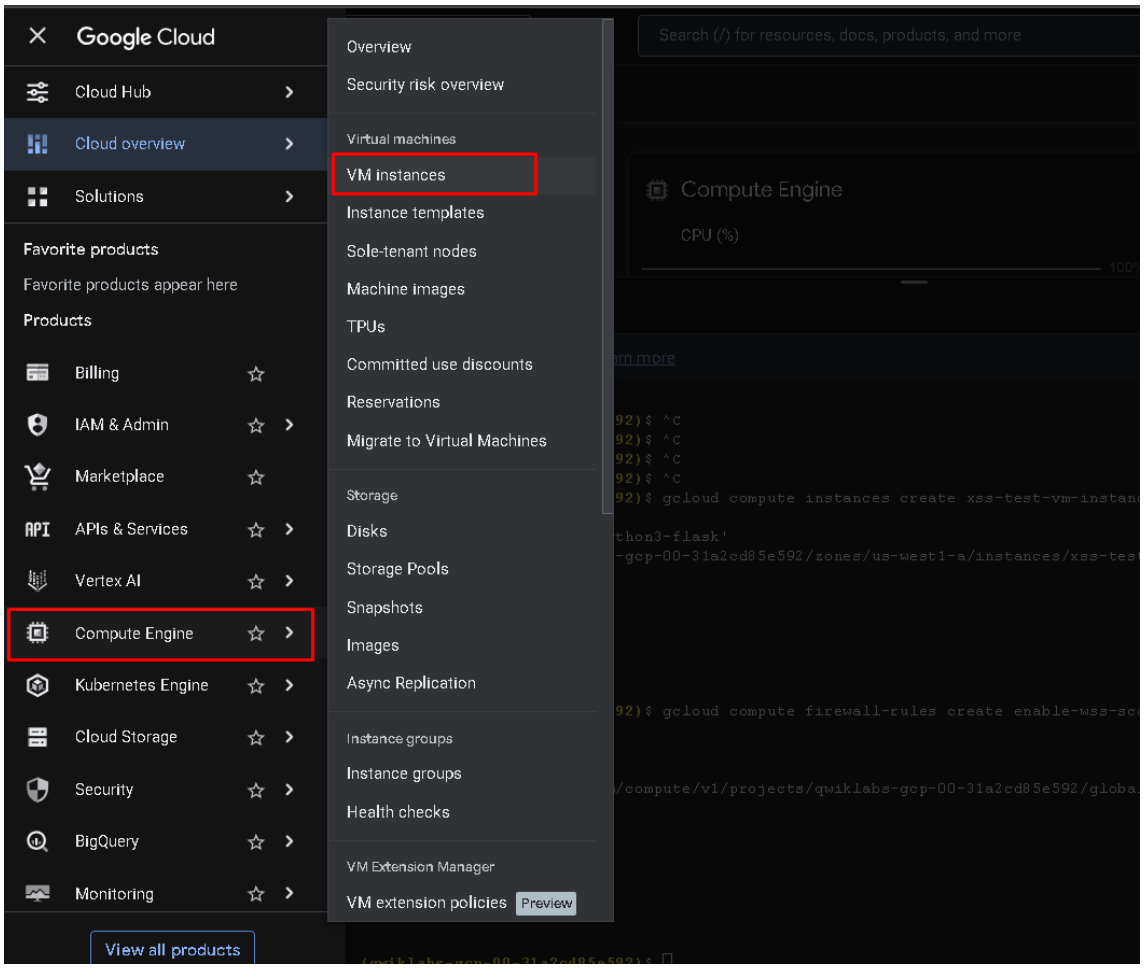
You have successfully completed this task.

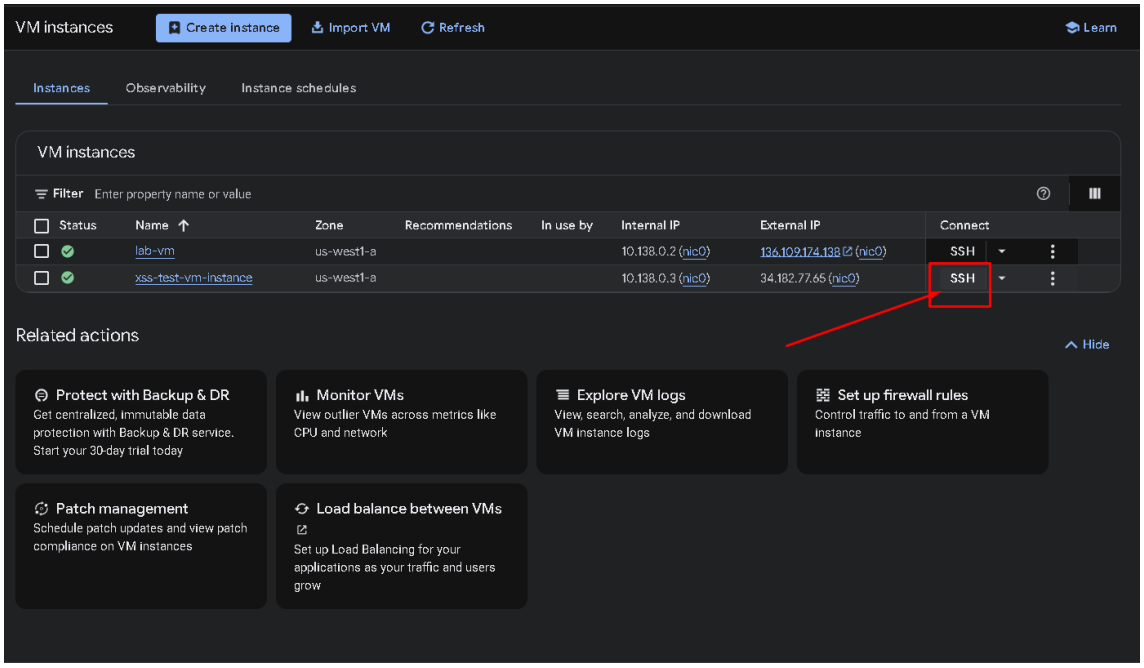
Tarefa 2: configurar e executar o aplicativo vulnerável

```
student_01_5eae39dd9135@cloudshell:~ (qwiklabs-gcp-00-31a2cd85e592)$ gcloud compute firewall-rules create enable-wss-scan \
--direction=INGRESS --priority=1000 \
--network=default --action=ALLOW \
--rules=tcp:8080 --source-ranges=0.0.0.0/0
Creating firewall...working.
```

```
student_01_5eae39dd9135@cloudshell:~ (qwiklabs-gcp-00-31a2cd85e592)$ gcloud compute firewall-rules create enable-wss-scan \
--direction=INGRESS --priority=1000 \
--network=default --action=ALLOW \
--rules=tcp:8080 --source-ranges=0.0.0.0/0
Creating firewall...working..Created [https://www.googleapis.com/compute/v1/projects/qwiklabs-gcp-00-31a2cd85e592/global/firewalls/enable-wss-scan].
Creating firewall...done.
NAME: enable-wss-scan
NETWORK: default
DIRECTION: INGRESS
PRIORITY: 1000
ALLOW: tcp:8080
DENY:
DISABLED: False
student_01_5eae39dd9135@cloudshell:~ (qwiklabs-gcp-00-31a2cd85e592)$
```




Google Cloud
Cloud Hub
Cloud overview
Solutions
Favorite products
Favorite products appear here
Products
Billing
IAM & Admin
Marketplace
APIs & Services
Vertex AI
Compute Engine
Kubernetes Engine
Cloud Storage
Security
BigQuery
Monitoring
View all products
Overview
Security risk overview
Virtual machines
VM instances
Instance templates
Sole-tenant nodes
Machine images
TPUs
Committed use discounts
Reservations
Migrate to Virtual Machines
Storage
Disks
Storage Pools
Snapshots
Images
Async Replication
Instance groups
Instance groups
Health checks
VM Extension Manager
VM extension policies
Preview
Search (/) for resources, docs, products, and more
Compute Engine
CPU (%)


VM instances
Create instance
Import VM
Refresh
Learn
Instances
Observability
Instance schedules
VM instances
Filter
Enter property name or value
Status
Name
Zone
Recommendations
In use by
Internal IP
External IP
Connect
lab-vm
us-west1-a
10.138.0.2 (nic0)
136.109.174.138 (nic0)
SSH
xss-test-vm-instance
us-west1-a
10.138.0.3 (nic0)
34.182.77.65 (nic0)
SSH
Related actions
Hide
Protect with Backup & DR
Get centralized, immutable data protection with Backup & DR service. Start your 30-day trial today
Monitor VMs
View outlier VMs across metrics like CPU and network
Explore VM logs
View, search, analyze, and download VM instance logs
Set up firewall rules
Control traffic to and from a VM instance
Patch management
Schedule patch updates and view patch compliance on VM instances
Load balance between VMs
Set up Load Balancing for your applications as your traffic and users grow

ssh.cloud.google.com/v2/ssh/projects/qwiklabs-gcp-00-31a2cd85e592/zones/us-west1-a/instances/xss-test-vm-instance?authuser=0&hl...

ssh.cloud.google.com/v2/ssh/projects/qwiklabs-gcp-00-31a2cd85e592/zones/us-west1-a/instances/xss-test-vm-instance?authuser=0&...

SSH-in-browser UPLOAD FILE DOWNLOAD FILE

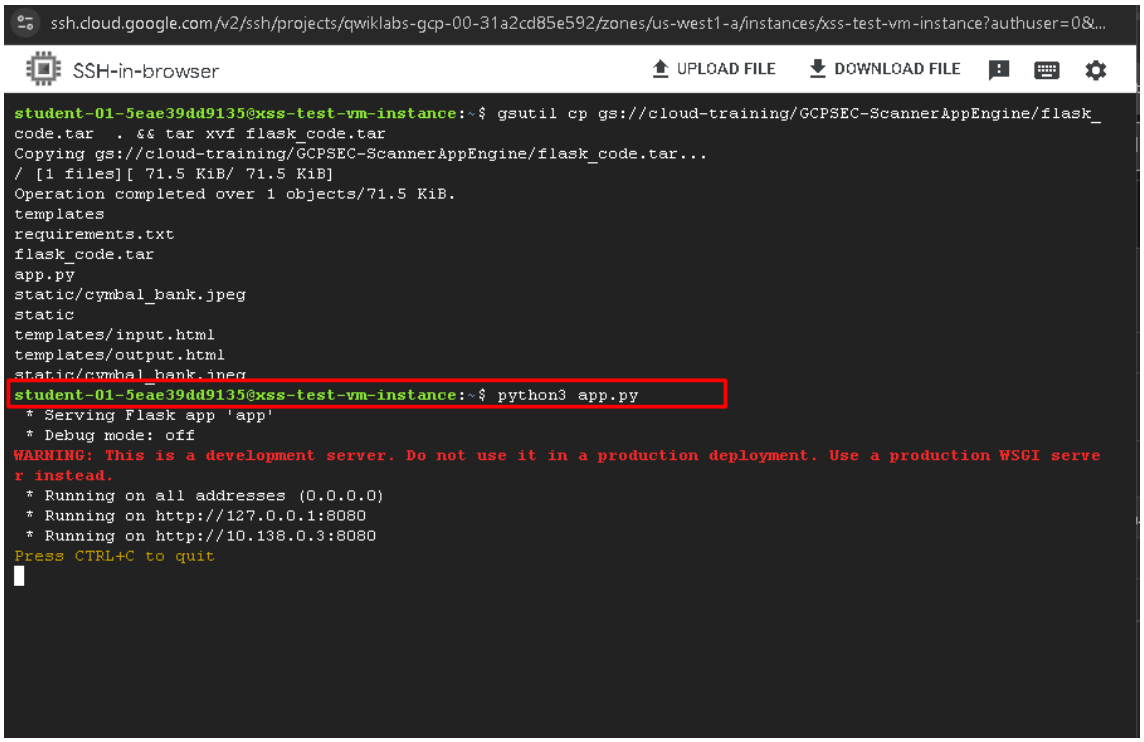
```
student-01-5eae39dd9135@xss-test-vm-instance:~$
```

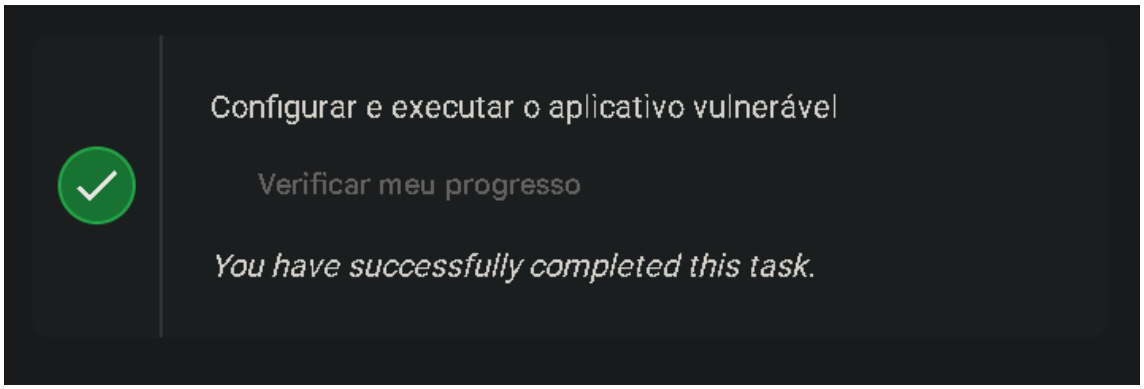
ssh.cloud.google.com/v2/ssh/projects/qwiklabs-gcp-00-31a2cd85e592/zones/us-west1-a/instances/xss-test-vm-instance?authuser=0&hl...

ssh.cloud.google.com/v2/ssh/projects/qwiklabs-gcp-00-31a2cd85e592/zones/us-west1-a/instances/xss-test-vm-instance?authuser=0&...

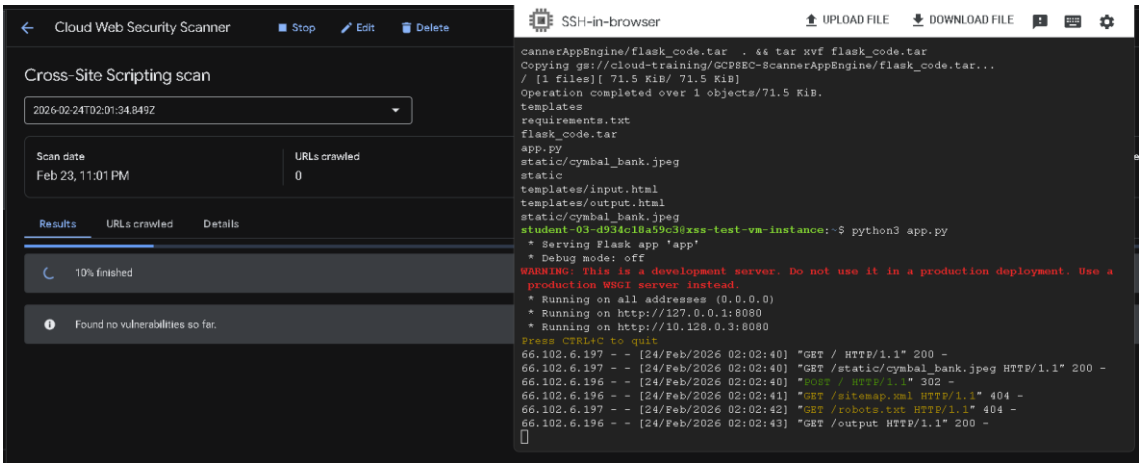
SSH-in-browser UPLOAD FILE DOWNLOAD FILE

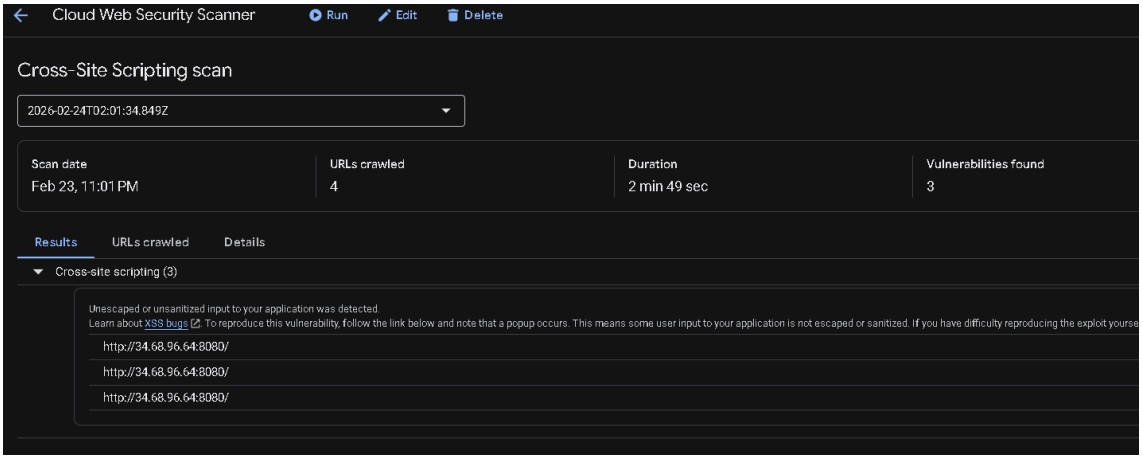
```
student-01-5eae39dd9135@xss-test-vm-instance:~$ gsutil cp gs://cloud-training/GCPSEC-ScannerAppEngine/flask_
code.tar  . && tar xvf flask_code.tar
Copying gs://cloud-training/GCPSEC-ScannerAppEngine/flask_code.tar...
/ [1 files][ 71.5 KiB/ 71.5 KiB]
Operation completed over 1 objects/71.5 KiB.
templates
requirements.txt
flask_code.tar
app.py
static/cymbal_bank.jpeg
static
templates/input.html
templates/output.html
static/cymbal_bank.jpeg
student-01-5eae39dd9135@xss-test-vm-instance:~$
```





Tarefa 3: acessar o aplicativo vulnerável


Cloud Web Security Scanner
Stop
Edit
Delete
Cross-Site Scripting scan
2026-02-24T02:01:34.849Z
Scan date
Feb 23, 11:01 PM
URLs crawled
0
Results
URLs crawled
Details
10% finished
Found no vulnerabilities so far.
SSH-in-browser
UPLOAD FILE
DOWNLOAD FILE
cannerAppEngine/flask_code.tar . && tar xvf flask_code.tar
Copying gs://cloud-training/GCPSEC-ScannerAppEngine/flask_code.tar...
/ [1 files][71.5 KiB/ 71.5 KiB]
Operation completed over 1 objects/71.5 KiB.
templates
requirements.txt
flask_code.tar
app.py
static/cymbal_bank.jpeg
static
templates/input.html
templates/output.html
static/cymbal_bank.jpeg
student-03-d934c18a59c3@xss-test-vm-instance:~$ python3 app.py
* Serving Flask app 'app'
* Debug mode: off
WARNING: This is a development server. Do not use it in a production deployment. Use a production WSGI server instead.
* Running on all addresses (0.0.0.0)
* Running on http://127.0.0.1:8080
* Running on http://10.128.0.3:8080
Press CTRL+C to quit
66.102.6.197 - - [24/Feb/2026 02:02:40] "GET / HTTP/1.1" 200 -
66.102.6.197 - - [24/Feb/2026 02:02:40] "GET /static/cymbal_bank.jpeg HTTP/1.1" 200 -
66.102.6.196 - - [24/Feb/2026 02:02:40] "POST / HTTP/1.1" 302 -
66.102.6.196 - - [24/Feb/2026 02:02:41] "GET /sitemap.xml HTTP/1.1" 404 -
66.102.6.197 - - [24/Feb/2026 02:02:42] "GET /robots.txt HTTP/1.1" 404 -
66.102.6.196 - - [24/Feb/2026 02:02:43] "GET /output HTTP/1.1" 200 -


Cloud Web Security Scanner
Run
Edit
Delete
Cross-Site Scripting scan
2026-02-24T02:01:34.849Z
Scan date
Feb 23, 11:01 PM
URLs crawled
4
Duration
2 min 49 sec
Vulnerabilities found
3
Results
URLs crawled
Details
Cross-site scripting (3)
Unescaped or unsanitized input to your application was detected.
Learn about XSS bugs. To reproduce this vulnerability, follow the link below and note that a popup occurs. This means some user input to your application is not escaped or sanitized. If you have difficulty reproducing the exploit yourse
http://34.68.96.64:8080/
http://34.68.96.64:8080/
http://34.68.96.64:8080/